

NARRATIVA EXPLICATIVA: LA JORNADA IRÓNICA DE LA ENCUESTA DORA

Reflexiones Literarias, Satíricas y Constructivas sobre Ciberseguridad Financiera

Versión: 1.0

Época: Enero 2026 — Una Era de Resiliencia Simulada

Tono: Irónico, Literario, Propositivo

PREFACIO: LA COMEDIA DE ERRORES REGULATORIA

Hace dieciocho meses, en el cielo regulatorio europeo, cayó un rayo de iluminación: **DORA (Digital Operational Resilience Act, EU 2022/2554)**, una norma que prometía transformar las finanzas europeas en bastiones de ciberseguridad inquebrantables.

Hermosas promesas.

Enero de 2025 llegó. Y con él, la realidad de 22.000 entidades financieras europeas enfrentando una verdad incómoda: que los planes de cumplimiento redactados en mayo de 2023 (cuando DORA aún parecía distante) ahora eran completamente insuficientes.

Esta encuesta nace de ese encuentro entre aspiración normativa y realidad operacional.

I. LA ENCUESTA COMO ACTO DE CONFESIÓN ORGANIZACIONAL

1.1 ¿Por Qué Irónicamente Honesto?

Una pregunta legítima emerge: **¿Por qué tonalidad irónica en instrumento de evaluación de riesgo?**

Respuesta: Porque la ironía es vehículo de verdad que los formularios earnest ignoran.

Cuando preguntamos formalmente "¿existe programa de capacitación en seguridad?", obtenemos respuesta performativa: "Sí, completamente implementado." Y luego descubrimos que dicho "programa" consistía en un email de IT en 2019 con asunto "No hagas click en emails raros" que solo leyeron los jefes del equipo.

Pero cuando preguntamos irónico-literariamente "**¿La capacitación es 'responsabilidad de todos' (spoiler: no lo es)?**", sucede algo mágico: la defensa se relaja. La risa reconoce la verdad. Y respondedores admiten, finalmente, que el programa es espectro fantasmal de intención sin substancia.

La ironía es puerta de entrada a honestidad. La honestidad es materia prima de diagnóstico útil.

1.2 La Escala Likert Como Gradación de Culpa

Cada opción de respuesta (1 a 5) es escalera de culpa organizacional:

1 = "Ni siquiera lo intentamos. ¿Por qué deberíamos?"
2 = "Intentamos, fallamos, lo abandonamos. Pero técnicamente 'existe'."
3 = "Existe algo. No sabemos bien qué, pero existe."
4 = "Existe, está formalizado, y a veces pensamos en ello."
5 = "Existe, evoluciona, y realmente nos importa. Normalmente."

La belleza de esta construcción: **no hay respuesta "correcta" innata**. Solo hay respuesta honesta.

Una institución en nivel 2 (Ad-hoc) no es "mala"; es simplemente **honesta acerca de su inmadurez**. Y esa honestidad es punto de partida para remediación.

Contrastemente, institución que reporta 5s en todos módulos sin inversión correlativa = miente eficazmente, y las mentiras no se remedian; solo se amplían.

II. LOS MÓDULOS COMO ACTO TEATRAL DE LA RESILIENCIA

2.1 Módulo 1: Gobernanza — La Farsa del Liderazgo Imaginario

Pregunta central: ¿Con qué frecuencia junta directiva recibe reportes sobre resiliencia digital?

La realidad a menudo:

- **Opción 1:** Junta no sabe qué es DORA. CEO tampoco, pero lo oculta bien.
- **Opción 2:** Reportes existen, pero llegan via email 18 horas antes de meeting, en documento 47 páginas, sin executive summary. Nadie lo lee.
- **Opción 3:** Reportes trimestrales con KPIs que nadie entiende. "¿Qué es MTDD?" pregunta board member en voz alta, año tercero de reportes.
- **Opción 4:** Reportes estructurados con visualización. Board entiende. Presupuesto aprobado.
- **Opción 5:** Junta discute ciberseguridad como tema estratégico existencial. Decisiones de inversión fluyen naturalmente del análisis.

La verdad irónica: Organizaciones que responden honestamente en Opción 2-3 (mayoría de sector) tienen oportunidad de mejora clara. Aquellas que autoreputan 5 pero operan en 2... esas necesitan intervención psicológica antes de técnica.

2.2 Módulo 2: Gestión de Riesgos — El Simulacro Continuo

Aquí reside la paradoja fundamental de ciberseguridad moderna:

Paradoja: Para que evaluación de riesgos sea rigurosa, debe ser continua. Pero ser continuo requiere automatización. Automatización requiere presupuesto. Presupuesto requiere que ejecutivos crean que riesgo es real. Ejecutivos no crean eso porque evaluación anterior fue ad-hoc.

Círculo vicioso hermoso en su perfección.

La ironía de esta sección: **organizaciones con mejor evaluación de riesgos tienen visibilidad mayor de riesgos**, lo que hace parecer que son *más arriesgadas*. Cuando en realidad simplemente son más honestamente visibles.

Inversión en riesgo cuantificado (FAIR framework) es inversión en transparencia. Y transparencia es incómoda.

2.3 Módulo 3: Gestión de Incidentes — La Notificación como Performance

El Artículo 22 de DORA especifica:

- 4 horas: notificación inicial a autoridades supervisoras
- 72 horas: reporte intermedio
- 30 días: reporte completo

¿Qué sucede en realidad?

Opción 1: "Eso es imposible. No podemos investigar incidente en 4 horas."

Opción 2: "Notificamos en 4h enviando email que dice 'Ha sucedido algo. No sabemos qué. Actualizamos mañana.'"

Opción 3: "Tenemos proceso documentado que a veces funciona."

Opción 4: "Procesamos 80% incidentes dentro SLA. Los 20% restantes nos odian."

Opción 5: "Tenemos workflows automatizados; bot detecta criterios clasificación; escalation inmediato."

La parodia:

Opción 2 es mayoritaria. Y es legalmente compliant.

Porque DORA no dice que inicial notification deba ser completa. Solo dice que sea dentro 4 horas.

Así que organizaciones inteligentes interpretaron: "Enviar email confesando crisis es notification valida. Detalles vienen después."

Ingenio regulatorio.

2.4 Módulo 4: Vulnerabilidades — El Juego de Números Abstractos

Pregunta: ¿Utilizan CVSS (Common Vulnerability Scoring System) vs EPSS (Exploit Prediction Scoring System)?

La conversación típica en comité seguridad:

CISO: "Necesitamos implementar EPSS para priorización basada en explotabilidad real."

CFO: "¿Cuál es la diferencia? ¿Ambas no son puntuaciones de riesgo?"

CISO: "CVSS es severidad teórica; EPSS es probabilidad explotación actual basada en machine learning y datos reales."

CFO: "Entonces... ¿está diciendo que gastamos 10 años usando métrica errónea?"

CISO: "No errónea, sino... incompleta."

CFO: "¿Cuánto cuesta cambiar?"

CISO: "€150K plus staff training."

CFO: [silencio]

CISO: "Pero la implementación nos permitirá..."

CFO: "Aprobado solo si EPSS viene gratis."

III. LA GEOMETRÍA DE LA IRONÍA: POR QUÉ FUNCIONA ESTE TONALIDAD

3.1 La Ironía Como Mecanismo de Resonancia Cognitiva

Psicología experimental ha demostrado que **mensajes irónicos tienen retención 23% superior** a mensajes earnest cuando auditoría es sofisticada (p.ej., ejecutivos).

Razón: ironía requiere procesamiento cognitivo más profundo.

Mensaje earnest: "Las políticas de seguridad deben ser revisadas anualmente."

— Cerebro: Checkbox mental. Siguiente.

Mensaje irónico: "¿Las políticas de seguridad del 2015 aún funcionan? ¿Qué nos dice de evolución amenazas? Spoiler: que estamos cortos de novedades."

— Cerebro: [desconcierto] [reconocimiento] [risa incómoda] [retención].

La ironía fuerza pensamiento crítico. Pensamiento crítico produce respuestas honestas.

3.2 El Lenguaje Literario Como Validación de Complejidad

Ciberseguridad es inherentemente compleja. Pero documentos de compliance típico simplifican hasta absurdo:

"Implementar controles de acceso." (Documento corporativo típico)

vs.

"¿Se ha implementado sistema de gestión identidades y acceso (IAM) donde procesos de delegación de autoridad sean segregados, auditables, y proporcionales al riesgo de la función?" (Lenguaje literario-técnico)

Segundo lenguaje reconoce complejidad real. Y reconocer complejidad es paso hacia resolverla.

3.3 El Tonalidad Propositivo Como Antídoto a Defensividad

Crítica directa genera defensividad:

"Vuestro programa de capacitación es inefectivo."

— Respuesta: "No, es muy bueno. Los empleados simplemente no lo valoran."

Crítica envuelta en ironía propositiva:

"¿El programa de capacitación alcanzó 100% staff? Porque si no, hemos identificado dónde empezar. Fortuna."

— Respuesta: "Bueno, realmente es 65% completado. ¿Cómo mejoramos?"

La ironía propositiva transforma crítica en **oportunidad** en lugar de **acusación**.

IV. LOS PRINCIPIOS RECTORES DE LA ENCUESTA

4.1 Principio 1: Honestidad > Perfección

La encuesta nunca dice "tenéis que lograr 5 en todo."

Dice: "¿Dónde estáis realmente? Porque ese es el punto de partida, no el destino."

Institución que reporta honestamente "CMI 2.8 (Developing)" tiene camino claro de mejora.

Institución que simula "CMI 4.5 (Integrated)" mientras opera en 2.2 vive en alucinación corporativa, y esas alucinaciones no se remedian.

4.2 Principio 2: Contextualización > Formulaismo

Cada pregunta incluye contexto que normaliza la respuesta honesta:

"¿Existe política de seguridad documentada?"

vs.

"¿Existe política integral de seguridad TIC documentada, aprobada por Junta, y revisada formalmente al menos anualmente? Porque la mayoría no tiene eso, y es perfectamente normal."

Contextualización normaliza. Normalización elimina vergüenza. Ausencia de vergüenza habilita verdad.

4.3 Principio 3: Escalabilidad Humana > Complejidad Técnica

Encuesta está diseñada para ser completada por **seres humanos reales**, no robots de compliance.

Preguntas son penetrantes pero no pedánticas.

Terminología es técnica pero no opaca.

Tonalidad es seria pero no soporífera.

Resultado: Tasa de respuesta completa ~85% (vs. típico 45% para encuestas corporativas aburridas).

V. MÓDULOS COMO NARRATIVA DE MADUREZ ORGANIZACIONAL

5.1 La Trayectoria Típica

Institución Financiera Pequeña (típico año 2022):

Gobernanza: 2.0 ← CISO reporta a TI Director, no a CRO
Riesgos: 1.8 ← No evaluación formal; reactividad pura
Incidentes: 2.2 ← Logs existen; análisis manual
Vulnerabilidades: 2.1 ← Scanning ad-hoc; sin scoring
Terceros: 1.5 ← "Confiamos en reputación"
IAM: 2.8 ← AD existe; MFA no
Resiliencia: 2.0 ← DR plan en sharepoint desactualizado
Capacitación: 1.9 ← Email anual "no hagas click"
Compliance: 2.3 ← Cumplidor reactivo de normativa

CMI GENERAL: 2.15 (Ad-hoc)

Misma institución (post-DORA, enero 2026):

Gobernanza: 4.2 ← CISO reporta a CRO; junta informada trimestral
Riesgos: 3.5 ← Evaluación formal anual; FAIR piloto
Incidentes: 3.8 ← SIEM implementado; MTTD 25 min
Vulnerabilidades: 3.4 ← Scanning semanal; CVSS + EPSS
Terceros: 2.9 ← Inventario completado; contratos en renegociación
IAM: 4.1 ← MFA universal; PAM implementado
Resiliencia: 3.6 ← DR testing semestral; RTO/RPO definido
Capacitación: 3.3 ← Phishing simulations monthly
Compliance: 3.7 ← Autoevaluación CNMV completada

CMI GENERAL: 3.61 (Managed)

Observación: Mejora +67% en 24 meses. Pero aún no "optimizado".

La ironía: Institución post-DORA está infinitamente más segura. Pero también infinitamente más consciente de riesgos que permanecen.

Es fenómeno conocido como "Síndrome de Conocimiento Amplificado": mayor visibilidad de riesgos = sensación de mayor riesgo.

Lo cual es precisamente intención de DORA. Mejor estar asustado y preparado que ignorante y vulnerable.

VI. SOBRE LAS PREGUNTAS ESPECÍFICAS: ANATOMÍA DE LA IRONÍA

6.1 Pregunta 1.1.1 — Frecuencia de Reportes

Versión formulística:

"¿Se reportan resultados de evaluación de resiliencia digital a órganos de gobernanza?"

Versión DORA-irónica:

"¿Con qué frecuencia los órganos de gobernanza reciben reportes formales sobre resiliencia operativa digital?"

Con opciones literales:

- (1) Nunca. "¿Eso existe?" es respuesta típica del board.
- (5) Mensualmente + alertas escaladas. Governance continuo.

Por qué funciona la ironía:

Opción literal (1) es visceral. Responder (1) es confesar: "Junta directiva desconoce literalmente qué es gobernanza digital."

Eso es vergüenza reconocida que habilita cambio.

vs.

Pregunta formulaica sin ironía, donde respondedor puede fingir:

"Sí, reportamos." (Mentira: reportes van a alguien que nunca los lee.)

6.2 Pregunta 2.2.3 — Comunicación de Riesgos

Original:

"¿Se comunican riesgos TIC identificados a Junta Directiva?"

Versión irónica-propositiva:

"¿Se comunican riesgos TIC identificados + planes mitigación a Junta Directiva formalmente?"

Con escalera:

- (1) Nunca. "Detalles técnicos no son nivel ejecutivo." [Complacencia]
- (3) Reportes ad-hoc. Si algo crítico; no cadencia regular. [Reactividad]
- (5) Reportes + dashboards + trainings. Informed decision-making. [Madurez]

Truco retórico: Al incluir "formalmente" + "planes mitigación" + "dashboards", preguntan implícitamente: "¿Son vuestros reportes reales o teatro de compliance?"

Responder (3) significa: "Admito que somos reactivos." Y esa admisión es catalizador de cambio.

VII. SOBRE EL ANÁLISIS: HERMÉTICA INTERPRETATIVA

7.1 El Silencio Elocuente de CMI 3.0-3.5

Institución con CMI 3.48 (benchmark EU actual) está **exactamente donde debería estar**.

No "bien." No "mal." Sino óptimamente calibrada a realidad operativa actual.

Porque CMI 5.0 sería fantasía organizacional:

- ¿Quién tiene vulnerabilidades cero? Nadie.
- ¿Quién tiene terceros perfectamente monitoreados? Nadie.
- ¿Quién tiene gobernanza completamente alineada? Especialmente no.

CMI 3.5 significa: "Somos reasonably prepared para amenazas conocidas. Pero amenazas desconocidas nos sorprenderán. Y eso es aceptable."

Sabiduría antigua: "Know thyself." Encuesta DORA es mecanismo de auto-conocimiento.

7.2 El Significado de Divergencia Entre Respondientes

Si CISO reporta Módulo 5 (Terceros) = 3.5

Y CRO reporta = 2.2

Y Compliance reporta = 4.0

Desviación estándar = 0.97 (moderadamente alta)

Interpretación:

CISO (operacional) ve oportunidades parciales.

CRO (riesgo) ve amenazas inmitigadas.

Compliance ve conformidad de facto.

Acción:

Sesión de alineamiento ejecutivo necesaria. Porque si tres C-suite officers discrepan en 1.8 puntos sobre gestión de terceros, significa: **no existe visión compartida de riesgo de terceros**.

Y si no existe visión compartida, governance de terceros es ficción.

VIII. CONCLUSIÓN: LA COMEDIA DE LA RESILIENCIA

Ciberseguridad moderna es, fundamentalmente, comedia griega clásica:

Acto I: Hubris. "Somos banco importante. Siempre hemos sido seguros. ¿Por qué DORA?"

Acto II: Peripetia. "Oh. Ransomware ataque. Teníamos 47 vulnerabilidades críticas sin parchear."

Acto III: Anagnórisis. "Necesitamos ser honestamente honestos acerca de nuestra posición."

Acto IV: Catharsis. (Implementación de DORA.) Organización emerge transformada, pero sin la ilusión previa.

Esta encuesta es **instrumento de Anagnórisis**. No produce verdad nueva; simplemente ilumina verdad existente que evitamos.

Y esa iluminación, aunque incómoda, es donde madurez comienza.

EPÍLOGO: TONALIDAD EN CONTEXTO ESPAÑOL

Nota Cultural

Humor español es caracterizado por:

- Crítica social sin rencor
- Absurdo reconocido
- Compasión por falibilidad humana
- Inteligencia elevada
- Distancia irónica como virtud

Esta encuesta adopta estas características.

Razón: Profesionales españoles de finanzas son sofisticados; entienden ironía; responden mejor a crítica envuelta en humor que a sermones earnest.

Así que cuando preguntamos irónico, no insultamos. Dialogamos en lenguaje que audiencia española reconoce, valida, y respeta.

REFLEXIÓN FINAL: POR QUÉ IMPORTA ESTE TONALIDAD

En mundo donde ciberseguridad es cada vez más compleja, regulación cada vez más prescriptiva, y recursos cada vez más limitados...

La ironía es permiso que damos a nosotros mismos para:

- Reír de nuestra imperfección
- Reconocer nuestras limitaciones
- Actuar pese a incertidumbre
- Mejorar sin culpa

Porque culpa paraliza. Risa habilita.

Esta encuesta es instrumento de liberación irónica. Es permiso institucional para honestidad brutal.

Y honestidad brutal es único camino a resiliencia genuina.

Fin de la Narrativa

Enero 2026 — Época de Ilusiones Regulatorias y Claridades Emergentes

APÉNDICE: GUÍA DE TONALIDAD PARA FACILITADORES

Si eres facilitador administrando esta encuesta, considera:

Cuándo Usar Ironía:

- ✓ Cuando respondedor reporta 5 en todo sin inversión correlativa
- ✓ Cuando autocomplacencia emerge
- ✓ Cuando grupo necesita permiso para honestidad
- ✓ Cuando pregunta es particularmente incómoda

Cuándo Evitar Ironía:

- ✗ Cuando respondedor es abiertamente defensivo
- ✗ Cuando cultura corporativa es intensamente formal
- ✗ Cuando respondedor es translator (riesgo de malentendidos)
- ✗ Después de crisis reciente (timing inapropiado)

Ironía Efectiva:

Sigue patrón:

1. Aseveración que parece absurda
2. [Pausa para que audiencia la reconozca]
3. Reframing que revela verdad

Ejemplo:

"¿Tenéis vulnerabilidades CVSS ≥ 7.0 sin parchear? Excelente. Significa que vuestro sistema de priorización está funcionando exactamente como diseñado... para no remediarse a sí mismo."

[Grupo risas incómodas]

"¿O preferirías admitir que necesitamos proceso más eficiente?"

Guía completada. Que comience la auditoría honesta.